

T2 v2 设计说明

独立、证据驱动短流程

目标与取舍

输入公开公告或材料包，以及已经存在的本地 Git 仓库，生成可复核的 VulnGym 记录。用户不必先指定源码路径、候选编号或内部任务 ID；模型应结合公告、历史与实际源码自行发现入口和缺陷位置。输入支持单份公告、简单报告 JSONL，以及带本地缓存和仓库映射的 GHSA URL 列表。

目标既包括完整条目，也包括有用的部分结果：未知版本或入口不应清空已经建立的项目、标题和证据，更不能用空 SHA、行 0 或猜测代码补齐记录。完整输出遵循 SCHEMA.md 的 15 个字段；自动记录始终 verify=0。完整度、可追溯性与语义正确性分别评价，不以“产出 JSON”代表分析成功。

独立模块与数据流

当前 vulngym_t2 包含 **15 个 Python 模块（计入三个包入口文件）**，运行时只导入本包和标准库，不再导入旧 vulngym_agent 或 sealed/orchestrator 路径。有用的低层实现收进 _vendor，模型 HTTP 通信由本包 transport 承担；交付不依赖旧大工程的隐式导入链，也没有再搭一个 agent 框架。

模块组	文件与责任
输入与入口 (4)	__init__、__main__、cli、intake：参数、材料、输入错误与批次调度。
分析与产物 (4)	repository、pipeline、output、report：读源码、模型循环、终检、离线自评。
模型通信 (2)	llm、transport：JSON 请求、用量与共享账本、停止状态。
随包基础实现 (5)	_vendor/_init__、bounded_process、git_repository、models、schema_adapter：受限进程、Git 对象与格式规则。



模块通过普通 JSON 兼容字典协作，证据 ID 由控制器分配。每份输入独立处理，完成后立即落盘；最终排序条目并聚合报告。report 只读取公开汇总和 review 生成中文自评，不访问目标或调用模型，也不能把自动自评包装成人工验收。

工具和提示词架构

模型只有五种只读能力：`inspect_commit` 看提交及父节点，`list_files` 发现目录，`search_code` 搜索线索，`read_diff` 理解修改，`read_file` 取得指定版本的真实代码。搜索和差异用于导航，不能替代最终文件读取。源码、公告与提交说明都是数据，不能改变权限，也不会被执行。

提示词分清固定任务与字段规则、当前输入与修复候选、工具实际返回证据三层。响应只分“请求工具”和“提交草稿”，不复制复杂工作流配置。控制器可预读修复候选及差异，但不会自动认定 `fix`、`HEAD` 或 `fix parent` 就是漏洞版本；模型仍需解释版本与漏洞行为的对应关系。

每项字段附 `supported/uncertain/missing/conflicting`、简短理由和现有证据引用，猜测值单独保留。提示词要求先发现路径，再窄范围读取，区分真正可调用的处理器或入口读取与中途 `helper`；窗口从函数内部开始时，应补读外围定义或调用者。类似处理器、替代入口和兄弟调用点不能串成一条 `trace`。工具、上下文和调用次数均有界，重复读取不能无限消耗预算。

工具请求与响应按因果顺序进入对话；证据只覆盖实际展示的内容，截断必须可见，不能把未读部分当成已知。工具失败保留错误，不赋予支持状态；模型、工具和输入失败分别记录。已处理记录可保留，强制中断时当前输入或汇总仍可能未写完，因此不承诺任意故障下无损续跑。

首次草稿先做本地 `schema`/源码预检查，将实际错误与坐标修正反馈给原有的一次同模型自查，不另加请求或无限修复。自查只据已有证据重看版本、入口和路径，可回改或降级字段；遗漏字段不抹去此前有依据的工作。保存短计划、动作、理由与引用，不保存隐藏推理。同源判断仍可能重复犯错，自查不等于独立审核。

终检：来源与语义边界

来源 ID、公告链接、固定 `origin` 和 `verify` 由控制器持有。非空位置须引用同一选定 `commit`、同一路径且包含逐字代码的成功 `read_file` 结果，再由仓库读取器检查源码。仅引用公告、搜索命中或补丁不够。`Schema` 负责格式，源码检查负责位置与字节，两者都不证明漏洞语义。

字段理由帮助人工区分“事实取自哪里”和“为何把它解释为入口或缺陷”。引用编号存在仅说明可追溯，不自动证明其与结论相关；例如同文件中有外部输入和危险 `API`，仍需调用或控制关系证据。不同版本或多个入口混在一起时，应降级相关字段，而不是拼成看似连贯的链。

终检：坐标修正与可用草稿

针对“代码引用正确但行号偏移”，终检允许窄修正：原行号也须在已读窗口内，片段在所引用的同提交、同路径文本中逐字且唯一匹配，才纠正行坐标并记录改动。不修改代码、文件、commit 或语义置信度；重复匹配、窗口外位置和未读代码不能修复成答案，修正后仍须核验源码。

无依据的必需字段在 `draft_fields` 保持空值，建议值与错误进入 review，其他已知字段继续保留。可选 trace 未建立时导出 []，原建议步骤、状态和错误仍留待人工检查，不因未证明的可选路径阻断具备核心字段的条目。必需内容通过终检才进入 `entries.jsonl`；`reports.jsonl` 只聚合这些条目，草稿、输入失败和未处理输入分别统计。

迭代教训与质量边界

旧窄候选接口便于限制搜索，却容易把模型困在用户预选的错误范围；整体成败式收集又会丢失有用字段。重建把自主性放在证据发现，把限制放在工具权限、读取范围和逐字段检查。随包模块消除了旧导入链；坐标修正与可选 trace 处理则避免把表示问题误当成整体无效，但不能成为放宽证据的借口。

开发诊断曾出现只得到草稿、响应体为空和非法 JSON。这些运行用于识别字段不足、表达偏差与服务失败，不是验收成功案例，也不是盲测或准确率证据。应保留当时证据、错误和实际用量，明确改动解决了什么问题，而不是不断重试换取一次好看的完整输出。

目前每份输入最多生成一条入口记录。历史缺失、重命名、多提交修复、跨文件关系和材料截断仍会漏证据；不执行目标也意味着没有动态利用验证。人工尤其应复核项目与标题是否同源、版本是否受影响、EP 是否可达可控、CO 是否真是缺陷，以及二者是否属于同一漏洞链。过度谨慎的草稿与过度自信的错误候选都应单列；缺少独立标签时不宣称 F1 或准确率。

效果报告应同时呈现输入可用性、完整与部分产物、具体语义疑点、耗时及 HTTP/token 用量。少量真实诊断只说明该次表现；自动汇总不应把未处理输入藏到分母外，也不能用调用数或输出长度替代质量结论。

T1 集成与非空 trace 为可选扩展。详细命令、授权预算和故障处置见 `README_T2_V2.md`；演示及人工复核清单见 `docs/t2_v2_demo.md`。本短设计说明当前实现和取舍，不代替真实产物与独立质量评价。